

Mobile APP Personal Information Security Detection and Analysis

Shuang Li

Shanghai Key Laboratory of
Computer Software Evaluation,
Shanghai Computer Software
Technology Development Center,
Shanghai, China ls@sscenter.sh.cn

Meng Zhang

Shanghai Key Laboratory of
Computer Software Evaluation,
Shanghai Computer Software
Technology Development Center,
Shanghai, China zm@sscenter.sh.cn

Che Li

Shanghai Key Laboratory of
Computer Software Evaluation,
Shanghai Computer Software
Technology Development Center,
Shanghai, China liche@sscenter.sh.cn

Yue Zhou

Shanghai Key Laboratory of
Computer Software Evaluation,
Shanghai Computer Software
Technology Development Center,
Shanghai, China zhouyue@sscenter.sh.cn

Kanghui Wang

Shanghai Key Laboratory of
Computer Software Evaluation,
Shanghai Computer Software
Technology Development Center,
Shanghai, China wkh@sscenter.sh.cn

Yaru Deng

Shanghai Key Laboratory of
Computer Software Evaluation,
Shanghai Computer Software
Technology Development Center,
Shanghai, China dyr@sscenter.sh.cn

Abstract—Privacy protection is a vital part of information security. However, the excessive collections and uses of personal information have intensified in the area of mobile apps (applications). To comprehend the current situation of APP personal information security problem of APP, this paper uses a combined approach of static analysis technology, dynamic analysis technology, and manual review to detect and analyze the installed file of mobile apps. 40 mobile apps are detected as experimental samples. The results demonstrate that this combined approach can effectively detect various issues of personal information security problem in mobile apps. Statistics analysis of the experimental results demonstrate that mobile apps have outstanding problems in some aspects of personal information security such as privacy policy, permission application, information collection, data storage, etc.

Index Terms—information security, mobile APP, personal information, software testing

I. INTRODUCTION

With the development of human civilization, the carriers and the communicating methods of information are constantly changing. Changing from mouth to letters, from disks to the internet, the storage, sharing, and use of information have become more and more convenient. Consequently, the value and security of information have also become progressively more important. Nowadays, mobile technology and smartphone equipment are the top two most commonly used popular terms in the world. Nearly 90% of the world's population owns a smartphone. According to the statistics from the Ministry of Industry and Information Technology of China, the number of mobile apps released on the Chinese market is 3.45 million in 2020 [1]. The data from APP ANNIE [2] demonstrates that the number of global APP downloads is 218 billion in 2020, the

expenditures of APP store users are \$143 billion, and the average daily APP usage time of users is 4.2 hours. Human beings are gradually moving towards the era of mobile Internet marked by smartphones. From social entertainment to mobile payment, smartphones have penetrated every part of our lives and works [3]. As a result, more of our important personal information are exposed on the mobile Internet, which will lead to new threats and new risks to information security.

Privacy security, or personal information security, is the most relevant part of information security for everyone. For instance, due to irregular industry development and insufficient supervision, the quality of mobile apps is uneven. The security incidents, such as malicious charging, eavesdropping, hacking, illegal personal information collecting, mandatory permission requesting, over-frequent permission requesting, and vulnerability exploiting have occurred frequently. In March 2018, Cambridge Company launched a test product by utilizing the interface of Facebook's open platform, which obtained about 50 million personal information of users and their friends on Facebook [4]. In November 2018, China Consumer Association [5] released a report called *Evaluation report of personal information collection and privacy policy for 100 apps*, which demonstrated that some well-known China apps, such as Alipay, Meitu Xiuxiu, have excessive collection of users' personal information problem, and there are overall 91 apps having the behavior of excessive collection. The personal information security issues of mobile apps are relatively hidden, which usually occur without users' realizing. This paper focuses on Android applications and APP studies the personal

information security issues of mobile apps by means of combining static and dynamic detection technologies. Privacy security problems can be detected and exposed by these technical approaches, which has tremendous significance in assisting with the supervision of competent authorities, promoting the self-discipline of APP developers, and enhancing the safety awareness of users.

II. RELATED WORK

The detection technologies of mobile APP personal information security include manual review, static analysis technology, and dynamic analysis technology, etc. APP for the personal information security problem of Android APP, technical analysis is usually used to collect basic data rather than to determine whether an APP has security problem. The data collected by technical analysis are subsequently analysed by special personnel to confirm the existence of security problems. The manual review includes verification of privacy policy, APP function trial, etc.

Static analysis technology includes source file scanning, code feature analysis, and static taint analysis. By decompressing the apk file, global configuration file *AndroidManifest*, metadata file *META-INF*, executable file *classes.dex*, *lib* library, configuration file *ASSETS*, resource file *res*, and resource file *resources.arsc* can be obtained. Source file scanning technology is to scan the *AndroidManifest*, and resource file *res*, etc., which can gain the lists of system permissions declared by APPs and the lists of personal information collected by APPs [6]. Code feature analysis technology [7] is to scan the Smali or Java code which are engendered from decompiling DEX (Dalvik Executable File) files, and then gain the information of the sensitive API (Application Programming Interface) and the third-party SDK (Software Development Kit) based on code feature library. Static taint analysis technology [8] is to use static taint tracking to analyze the Smali or Java code, and then collect the sensitive APIs, build control flow graphs, and search for sensitive information flows.

Dynamic analysis technology includes Hook technology, dynamic taint analysis technology, and network packet interception technology. Hook technology [9] is to insert Hook to the sensitive API code and record the actual runtime, the parameters, and the call stacks, etc. when an APP calls the sensitive APIs. Dynamic taint analysis technology [10] is to utilize hook technology to insert code into sensitive APIs and then recording the spread of taint data by tracking the inserted code when the code is running. Once the marked personal information is transmitted, the behavior of personal information sending and privacy disclosure will be noticed. Network packet interception technology is to intercept network packets sent between APP and server through agent, which obtains the plaintext data and intercept the user information collected by the APP.

III. DETECTION APPROACH

Personal information may be spread out directly and illegally or be attacked then leaked out. These kinds of security incidents may occur in the process of data access, data operation and maintenance, data transmission, data storage, etc. Traditional detection approaches is to utilize black-box testing approach to test apk files, which is hardly to detect the security problems during the process of data processing, data storage, and data transmission after personal information collection. To deal with these security problems, this paper utilizes a combined approach of static analysis technology, dynamic analysis technology, and manual review, as shown in Fig. 1. The input data is the apk file of APP. In the static analysis technology part, the decompile technology, source file scanning technology, and static code feature analysis technology are used to realize the detection and analysis of permission requesting behaviors. In the dynamic part, sandbox technology, network packet interception technology, and dynamic taint analysis technology are used to realize the detection and analysis of permission uses, sensitive behaviors, and the use of third-party SDKs. This part can also reduce the false alarm of static detection. Finally, manual auditing is used to verify the results of technical detections and conduct additional detection that cannot be achieved by current detection technologies.

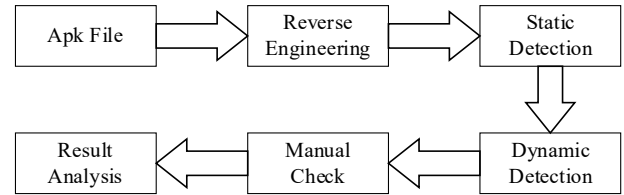


Fig. 1. Implementation process of the new detection method

A. Static Analysis Part

Fig. 2 illustrates the process of static analysis part, which includes the decompile technology, the source file scanning technology, and the static code feature analysis technology. The static analysis technology can realize the detection and analysis of requests for permissions and third-party SDK.

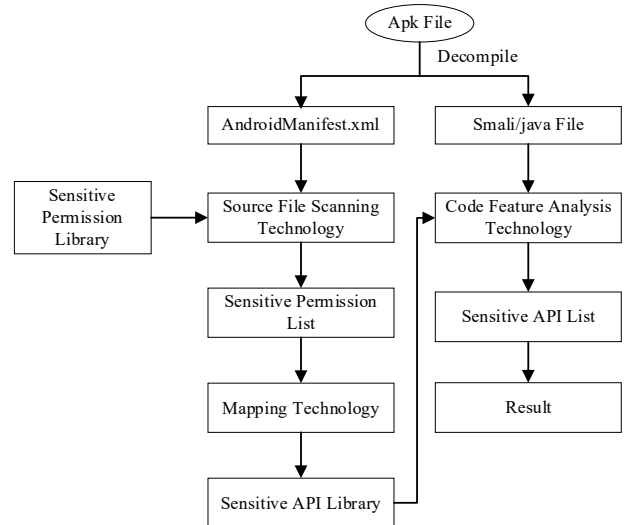


Fig. 2. Static analysis technology

Android provides a flexible permission mechanism. When an APP accesses some kind of resources, it needs to apply for relevant permissions in the global configuration file *AndroidManifest*. As is shown in Table 1, the file *AndroidManifest* consists of application name, version number, coding method, permission, reference library file, component. The official website of Android announces 174 permissions, which can be divided into 4 types: normal, dangerous, signature, and privileged. Risk level of these four types also increases from the former to the latter[11]. High-risk permissions involving user-sensitive data, such as accessing precise location permission ACCESS_FINE_LOCATION, are sorted out to establish a sensitive permission list. Source file scanning technology is used to scan the *manifest* file based on the sensitive permission list, which can accurately identify the information of system permissions applied by the APP.

TABLE 1
AndroidManifest.xml File Partial Content

Parameter	Function
<xmlns:android>	Android namespace
<android:versionName>	Version
<uses-feature>	Declares a single hardware or software feature that is used by the application.
<uses-permission>	Requests a permission
<permission>	Declares a security permission
<application>	The declaration of the application

Permissions correspond to sensitive API calls in the Android system [12]. Based on the research results of Adrienne et al. [13], this paper analyzes the mapping relationship between sensitive permissions and APIs and establishes a sensitive API library. Software reverse technology is used to decompile the *Dex* file which is one component of apk files to obtain APP source code. After that, code feature analysis technology is used to scan the code. During the scanning process, the use of sensitive API in APP can be detected based on the former established sensitive AIP library. Finally, the results of source file scanning and code feature analysis are analysed to determine whether the tested APP has problems of excessive access to permissions, violation of minimum information collection and so on.

B. Dynamic Analysis Part

Sandbox technology, dynamic Taint Analysis Technology, and network packet interception technology are used to realize the detection and analysis of permission uses and sensitive behaviors of APP, as shown in Fig. 3.

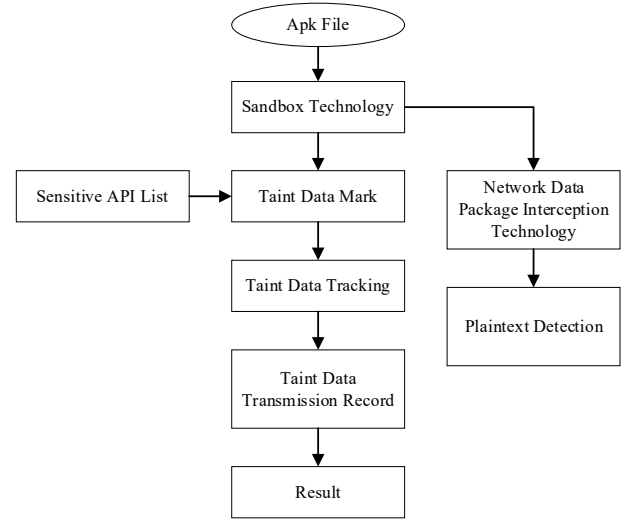


Fig. 3. Dynamic analysis technology

The taint source and taint aggregation point of privacy data transmission can be determined by the sensitive functions related to the sensitive permissions generated by the static analysis part.

- **Source confirmation.** Source is determined based on the mapping relationship between sensitive permissions and APIs. Tainted data is usually imported by user input, file, or network. For example, to trace the transmission of location information, functions such as `getLatitude()`, `getLongitude()`, `getLastKnownLocation()` can be used as Source.
- **Sink confirmation.** Some APIs that can store or send personal information are used as Sink, such as sensitive APIs related to the Internet: `Java.net.URL.connection()`, etc.
- **Taint propagation.** Firstly, take Source as the starting point and mark it to judge whether or not it spreads sensitive data. Secondly, take Sink as the endpoint and travers all path from the start to the end, recording paths which are related to sensitive permission call in APP.
- Conduct Taint Analysis on all sensitive APIs to detect sensitive behaviour of APP.

The sandbox technology is used to build dynamic APP running environment. Through dynamic taint analysis technology, the dynamic detection and analysis of APP's name, sensitive API call time, transfer parameter information, return value, and personal information collecting behaviors are realized. Key function calls are function calls involving privacy information such as getting geographic location information, reading contacts, device information. And sensitive behaviors includes: communication, reading application list, reading file IO (Input/Output), frequency of personal information collection, and so on. The network packet interception technology is used to intercept the network communication packets between APP and server and to judge whether the transmission process is encrypted.

C. Manual Check Part

To improve the accuracy of detection, the system simulator implementing the Android operating environment of apk is used to provide test environment for manual review. Manual review mainly includes two parts: one is to verify the results of detection technology, and the second one is to detect content that cannot be detected by detection technologies, such as whether the display mode of sensitive information in the privacy policy is normative. The privacy policy as the most direct communication carrier between enterprises and users undertakes the responsibility of mobile APP operators to explain to users and obtain their consent. At present, there is no unified and standardized privacy policy template in the market, this paper uses manual audits to complete the privacy policy detection and analysis of the compliance with relevant national standards.

IV. EXPERIMENTAL DESIGN

A. Data Sources

The Android system with more than 80% market share is selected as the research objects [6]. *China Mobile APP risk monitoring and evaluation report* in the third quarter of 2020 illustrates that there are approximately 800 channels for downloading mobile apps in China, and the top channel is called 'wandoujia' which includes 708790 applications and occupies 8.12% of the market share. Therefore, 40 mobile apps from 'wandoujia' are detected for personal information security detection. The experimental environment implements a 64-bit Windows system, Intel i7-4790 CPU, and 16GB memory.

B. Test Content

Android operating system was developed by Google in 2008, and there are more than 2.5 billion active Android devices, occupying 72.26% of the market share, which is far exceeding the 27.03% market share of IOS (iPhone operating System) as of early March 2020 [14]. Consequently, the rapid development of the Android system not only brings the rapid expansion of market share but also leads to serious security problems for Android. Android is a privileged operating system. Many operations in the process of interaction between smartphones and applications require obtaining permissions and access to resources or data in the device, which also afford opportunities to APP for cheating users. Also, attackers take advantage of vulnerabilities in the application to obtain sensitive information without the user's knowledge and carry out dangerous operations so that the users' privacy is leaked and their property losses [15].

This paper studies the Android operating mechanism and privacy leakage issues, etc. A total of 5 categories of 24 mobile APP personal information security problems are detected, which are 1) problems of privacy policy independence and readability, 2) personal information collection problem, 3) personal information storage problem, 4) personal information use and sharing and 5) user rights. The detection content

involves four layers of Android system architecture and the whole process of APP personal information collection, storage, and transmission. By testing 24 mobile APP personal information security problems, the permission utilization about telephone, location, multimedia, database, camera, and some others can be standardized. The detection can also reduce the occurrence of mandatorily permission requesting, over-frequently permission requesting, sensitive information leakage, malicious APP charges, eavesdropping, screen recording and illegal personal information collection.

C. Evaluation

A comprehensive test on the personal information security status of 40 apps finds that the current state of personal information security is disturbing. Based on the results of detection, 11 security risk issues are found, as shown in Fig. 4, which refer to the whole process of security content from personal information collection to storage, and to transmission.

- T1: Legality of information collection.
- T2: Minimum necessary of collecting personal information.
- T3: Independent selection of multiple business functions.
- T4: Authorization and agreement when collecting personal information.
- T5: Personal information protection policy.
- T6: Exceptions with authorized consent.
- T7: Transfer of sensitive personal information.
- T8: Transmission of personal sensitive information.
- T9: Responding to user requests.
- T10: Exceptions to obtaining prior authorization consent when sharing, transferring, or publicly disclosing personal information.
- T11: Management of third-party access.

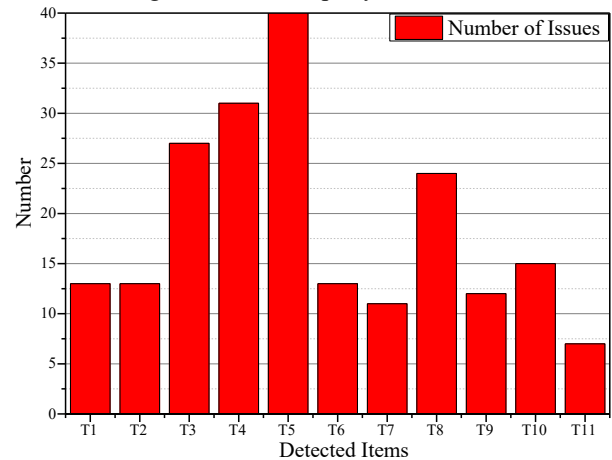


Fig. 4. Number of Issues

- (1) Requesting for permissions excessively, compulsorily, and frequently: When APPs are running, they request to obtain more than minimum necessary permissions, and declare the data, components, sensitive permissions, and other information

in the *manifest* file. The permissions which are unnecessary for the program running are used to collect user device information, personal privacy, and other personal information. According to the experimental results of 40 apps, it shows that 13 of them have the problem of applying for more permissions than the minimum necessary permissions, which causes unnecessary security threats. Moreover, in the process of registering, starting and using an APP, users are required to fill in some personal information unrelated to business functions. If they do not fill in the personal information, users will not be able to use the functions or the APP, and after the user explicitly refuses the permissions, the permission requiring prompt will pop up frequently. The result of the experiment of 40 apps shows that 27 of the 40 apps have such problems. The authorization and use of these sensitive permissions, which are not related to the business will steal users' address book, identity, property, SMS, photos, location, equipment information, and other information, resulting in the risk of user sensitive information leakage.

(2) Legality of information collection: Some apps induce users to input relevant personal information through points, rewards, gold coins, and other ways based on the detection of manual review. The results demonstrate that 13 of the 40 experimental apps have this kind of problem. Furthermore, it is found that some APPs do not explicitly inform the purpose, the method, and the scope of personal information collection and use, and hide personal information collection through dynamic detection. The results show that 31 of the 40 experimental apps have this kind of problem. Thus, gaining sensitive permissions of personal information may lead to the exposure of users' sensitive information and more serious consequences.

(3) Plaintext transmission problem: In the dynamic analysis, the network packets on the server are obtained by setting the proxy server. The results demonstrate that 11 of the 40 experimental apps use the HTTP protocol to transmit data in plaintext, which includes network identity, mobile phone number, email, precise positioning, and other information. Attackers can collect users' information by intercepting the communication between the APP and the server, or attack users with the replacement data.

(4) Privacy policy problem: The content of the privacy policy is incomplete, irregular, and unclear, etc. Users can not confirm the potential risks caused by filling in personal information and the content of the privacy policy should be demonstrated explicitly by enterprises. The results demonstrate that 40 of the 40 experimental apps have a privacy policy problem.

(5) Management problem of third-party access: It is found that 7 of the 40 apps have this kind of problems, for instance, the enterprise does not establish the management mechanism and workflow when accessing the third-party products or services, sensitive information is not identified to users, and

users have not reminded the rules of collecting information. Due to the universality and repeatability of third-party products or services, the third-party products or services has various potential security issues, such as divulging users' privacy information, using the application to execute unauthorized operations, and using host application to execute the malicious attack on users. Users' personal information is obtained without the user's knowledge, which will lead to users' inability to control the transmission path, use range, and risk coefficient of personal information so that it dramatically increases the risk level of malicious dissemination of user data.

According to the current security issues of APP personal information, the suggestions are listed from the following aspects: 1) users should download the APP in the formal channel, select the official version of apps, and install protection software to safeguard personal information, 2) users should carefully read the relevant privacy agreement to avoid registering suspicious apps when first use or before account registration, 3) users should set unnecessary permissions list of apps through smartphone, 4) when users discover their information leakage, they should proactively protect their rights in time and interests in time and reflect relevant departments, 5) enterprises should standardize the privacy policy and personal information collection, and clarify the subject of responsibility.

V. CONCLUSION

This paper uses a combined approach of static analysis technology, dynamic analysis technology, and manual review. Based on the research of the personal privacy policy of mobile APPs, a detection method of Android APP personal information security problem has been proposed. Through experiments on 40 mobile APPs, the effectiveness of the combined approach has been verified. The combined approach can effectively promote the standardization of mobile APP personal information security and force enterprises to collecting and using users' personal information more reasonably. Finally, the combined approach can prevent personal information leakage and other security issues, and effectively promote the healthy development of personal information security.

REFERENCES

- [1] Operation Monitoring and Coordination Bureau, "The operation of the Internet and related service industries in 2020," 1 February 2021. [Online]. Available: https://www.miit.gov.cn/gxsj/tjfx/zh/art/2021/art_675214708dd24ea486c919fced278e97.html.
- [2] Y. Chen and Y. Liu, "Analysis of personal information security status of mobile APP—Based on the test results of 30 mobile APP," China Management Informationization, pp. 192-193, September 2020.
- [3] APP ANNIE, "2021 Mobile Market Report," APP ANNIE, 2021. [Online]. Available: <https://www.appannie.com/cn/>.
- [4] S. Wei, "Analyze network operators' responsibility for security management of third-party applications from the Facebook data," Feature, pp. 56-59, April 2019.
- [5] China Consumer Association, "100 APP personal information collection and privacy policy evaluation report," China Consumer Association, 28 November 2018. [Online]. Available: <https://baijiahao.baidu.com/s?id=1618536466691317276>.

- [6] B. Zhao, X. Liu, X. Liu and Y. Hu, "Quantitative Evaluation Model of Personal Information," *Communications Technology*, vol. 53, no. 8, pp. 2019-2026, 30 August 2020.
- [7] P. Wu, . L. Yin, X. Du, L. Jia and W. Dong, "Graph-based Vulnerability Detection via Extracting," 2020 IEEE 20th International Conference on Software Quality, Reliability and Security Companion (QRS-C), pp. 38-45, 2020.
- [8] J. Zhang, C. Tian and Z. Duan, "FastDroid: Efficient Taint Analysis for Android Applications," 2019 IEEE/ACM 41st International Conference on Software Engineering: Companion Proceedings (ICSE-Companion), pp. 236-237, 2019.
- [9] N. Totosis and C. Patsakis, "Android Hooking Revisited," 2018 IEEE 16th Intl Conf on Dependable, Autonomic and Secure Computing, 16th Intl Conf on Pervasive Intelligence and Computing, 4th Intl Conf on Big Data Intelligence and Computing and Cyber Science and Technology Congress (DASC/PiCom/DataCom/CyberSciTech), pp. 552-559, 2018.
- [10] M. Zhao, H. Yang, P. Chen and Z. Yang, "Android software vulnerability mining framework based on dynamic taint analysis technology," 2019 IEEE 3rd Information Technology, Networking, Electronic and Automation Control Conference (ITNEC), pp. 2112-2115, 2019.
- [11] developers, "Building any application on the Android platform," developers, 2021. [Online]. Available: <https://developer.android.com/>.
- [12] Z. Aung and W. Zaw, "Permission-Based Android Malware Detection," INTERNATIONAL JOURNAL OF SCIENTIFIC & TECHNOLOGY RESEARCH, pp. 228-234, 2013.
- [13] A. P. Felt, E. Chin, S. Hanna, D. Song and D. Wagner, "Android Permissions Demystified," Proceedings of the 18th ACM conference on Computer and communications security, pp. 627-638, 2011.
- [14] GlobalStats, "statcounter," GlobalStats, March 2021. [Online]. Available: <https://gs.statcounter.com/os-market-share/mobile/worldwide>.
- [15] X. Jiang, "Research on Android Application Vulnerability Detection Technology Based on Machine Learning," Beijing University of Posts and Telecommunications, pp. 9-18, 2019.